

Botium Toys Security Audit Checklist - 2025

This document presents a comprehensive security audit for Botium Toys, evaluating the company's security controls, compliance alignment, and providing actionable recommendations to strengthen its cybersecurity posture.

1. Control Assessment

Control	Status	Notes
Least Privilege	Needs Improvement	Users have excessive permissions in several departments.
Firewalls & IDS	Partially Implemented	Perimeter firewalls exist, but IDS/IPS coverage is limited.
Encryption	Insufficient	Sensitive customer payment info not encrypted at rest.
Logging & Monitoring	Needs Improvement	Critical system logs not centralized or regularly reviewed.

2. Compliance Review

Standard	Compliance Status	Notes
PCI DSS	Partially Compliant	Cardholder data not fully encrypted or segmented.
GDPR	Non-Compliant	No formal data subject rights request handling process.
SOC 1 & 2	Not Certified	Internal controls require significant improvement before audit.

3. Key Recommendations

- Implement least privilege and enforce separation of duties.
- Introduce multi-factor authentication (MFA) across all critical systems.
- Establish regular maintenance and patching for legacy systems.
- Encrypt sensitive data, including customer payment information, at rest and in transit.
- Create and test disaster recovery and incident response plans.
- Introduce secure password policies and deploy a password manager.
- Centralize log collection and implement continuous monitoring with alerting.

4. Risk Ratings

Issue	Risk Level	Impact
Excessive Permissions	High	Potential insider threats and privilege misuse.
Lack of Encryption	Critical	Customer payment data at risk of compromise.
Legacy Systems	Medium	Unpatched systems vulnerable to known exploits.
Weak Logging	Medium	Delayed detection of breaches or anomalies.

■ This audit document is intended to guide Botium Toys in strengthening its cybersecurity posture for 2025 and beyond. Implementing the above recommendations will significantly reduce the risk of security incidents and compliance failures.